AURELIUS DIGITAL SYSTEMS PVT. LTD.

SECURITY INCIDENT RESPONSE & BUSINESS CONTINUITY MANUAL

SEC-IR-004 | Version 5.2

Field	Controlled value
Document ID	SEC-IR-004
Version	5.2
Effective date	2026-08-01
Review date	2027-07-31
Classification	CONFIDENTIAL
Owner	Aman Verma (Director-level lead, SOC & Incident Response) under Nikhil Varma (CISO)
Approver	Nikhil Varma (CISO)
Department	Information Security & Resilience
Applicability	Incident responders, system/data owners, managers, continuity coordinators, and all workers for reporting duties
Status	APPROVED - CONTROLLED INTERNAL DOCUMENT

Fictional enterprise notice: Aurelius Digital Systems Pvt. Ltd., its identities, systems and internal rules in this document are fictional.

Document Control

SEC-IR-004-DC01 - Document-Control Record

Field	Controlled value
Document ID	SEC-IR-004
Title	Security Incident Response & Business Continuity Manual
Version	5.2
Status	Approved - Controlled Internal Document
Effective date	2026-08-01
Review date	2027-07-31
Owner	Aman Verma (Director-level lead, SOC & Incident Response) under Nikhil Varma (CISO)
Approver	Nikhil Varma (CISO)
Department	Information Security & Resilience
Classification	CONFIDENTIAL
Applicability	Incident responders, system/data owners, managers, continuity coordinators, and all workers for reporting duties
Controlled repository	VaultPoint DMS
Distribution	Authorized workforce and functions according to classification and applicability
External-law treatment	Where a decision depends on external law or a client obligation not contained here, obtain verified guidance from Legal & Corporate Affairs.

Controlled-source rule: Convenience copies, screenshots and local notes do not supersede the controlled document or authoritative enterprise system for the relevant fact.

Revision History

SEC-IR-004-RH01 - Revision History

Version	Effective / status	Meaningful change
3.2	Prior controlled release	Initial controlled issue and consolidation of predecessor guidance.
3.7	Prior controlled release	Expanded scope, roles and source-of-truth controls.
4.2	Prior controlled release	Aligned enterprise systems, approval vocabulary and document interfaces.
4.6	Prior controlled release	Added clearer exception, recordkeeping and manager/accountability rules.
4.9	Prior controlled release	Refreshed operational workflows, conditional rules and cross-document handoffs.
5.2	2026-08-01	Current release aligned to enterprise governance baseline and approved process design.

Precedence: This document controls only within its approved subject. Specialist policies, standards and procedures control detailed requirements in their own subject matter; unresolved conflicts are escalated to the relevant Policy Owners.

SEC-IR-004-DG01 - Document Dependencies

Dependency type	Documents
Primary	
Control	

Table of Contents

1 Purpose, Scope and Manual Authority
- 1.1 Purpose
- 1.2 Incident types
- 1.3 Business continuity events
- 1.4 Relationship to security policy
- 1.5 No legal deadline inference

2 Incident Governance, Roles and Command Model
- 2.1 SOC & Incident Response
- 2.2 Incident Commander
- 2.3 CISO
- 2.4 MIEG
- 2.5 System/Data/Business Owners
- 2.6 DPO/Legal
- 2.7 Business Continuity
- 2.8 Communications

3 Severity Classification and Reclassification
- 3.1 SEV-1 Critical
- 3.2 SEV-2 High
- 3.3 SEV-3 Medium
- 3.4 SEV-4 Low
- 3.5 Potential impact
- 3.6 Reclassification and audit trail

4 Detection and Reporting
- 4.1 Worker reporting
- 4.2 SignalWatch alerts
- 4.3 EndpointShield alerts
- 4.4 DataGuard alerts
- 4.5 Vendor/client notifications
- 4.6 Out-of-band reporting

5 Initial Triage and Validation
- 5.1 Intake
- 5.2 Duplicate/event correlation
- 5.3 Scope estimation
- 5.4 Initial severity
- 5.5 Owner identification
- 5.6 Immediate protective actions

6 Incident Command and Escalation
- 6.1 Command activation
- 6.2 MIEG activation
- 6.3 Executive escalation
- 6.4 Specialist concurrence
- 6.5 Shift handover
- 6.6 Decision log

7 Containment Strategy and Emergency Change Control
- 7.1 Containment objectives
- 7.2 Account containment
- 7.3 Endpoint containment
- 7.4 Network/cloud containment
- 7.5 Data movement containment
- 7.6 Business impact trade-offs
- 7.7 Emergency change evidence

8 Credential Compromise and Identity Incidents
- 8.1 User credential compromise
- 8.2 Privileged compromise
- 8.3 Service account/API key compromise
- 8.4 MFA bypass
- 8.5 Session/token revocation
- 8.6 Recovery and recertification

9 Phishing, Business Email and Messaging Incidents
- 9.1 Reported phishing
- 9.2 Clicked link/attachment
- 9.3 Credential submission
- 9.4 Mailbox rule abuse
- 9.5 Internal propagation
- 9.6 Payment-fraud coordination

10 Malware and Ransomware
- 10.1 Single endpoint malware
- 10.2 Multi-endpoint outbreak
- 10.3 Ransomware indicators
- 10.4 Isolation
- 10.5 Destructive activity
- 10.6 Recovery decision
- 10.7 Extortion-contact boundary

11 Lost, Stolen or Unaccounted Devices
- 11.1 Immediate report
- 11.2 DeviceCentral actions
- 11.3 Access/session containment
- 11.4 Data exposure assessment
- 11.5 AssetSphere update
- 11.6 Travel-related loss

12 Data Exposure and Privacy Incidents
- 12.1 Wrong-recipient disclosure
- 12.2 Public exposure
- 12.3 Bulk data loss
- 12.4 Privacy Incident assessment
- 12.5 DPO coordination
- 12.6 External notification decision reserved to verified Legal/DPO process

13 Cloud, SaaS and Infrastructure Incidents
- 13.1 Compromised cloud identity
- 13.2 Misconfiguration exposure
- 13.3 Malicious API activity
- 13.4 SaaS tenant incident
- 13.5 Cloud service outage
- 13.6 Provider escalation

Table of Contents - continued

14 Insider Threat and Suspicious Internal Activity
- 14.1 Initial handling
- 14.2 Need-to-know investigation
- 14.3 Evidence preservation
- 14.4 HR/Legal coordination
- 14.5 Access containment
- 14.6 Avoiding premature conclusions

15 Vendor and Third-Party Incidents
- 15.1 Vendor notification intake
- 15.2 Critical Vendor prioritization
- 15.3 Access containment
- 15.4 Contract/procurement coordination
- 15.5 Evidence and assurance requests
- 15.6 Service continuity

16 AI, Model, RAG and Agent Incidents
- 16.1 Sensitive data submitted to AI
- 16.2 Prompt injection/indirect instruction
- 16.3 Model/API credential compromise
- 16.4 Unsafe agent action
- 16.5 RAG data exposure
- 16.6 Model integrity concern
- 16.7 AI governance coordination

17 Evidence Preservation and Investigation
- 17.1 Evidence principles
- 17.2 Log preservation
- 17.3 Endpoint/cloud evidence
- 17.4 Chain-of-custody style internal record
- 17.5 Interviews
- 17.6 Access to evidence
- 17.7 Third-party evidence

18 Incident Communications
- 18.1 Internal updates
- 18.2 Executive updates
- 18.3 Client communications
- 18.4 Employee communications
- 18.5 Media/public communications
- 18.6 Communication approvals

19 Eradication, Recovery and Return to Service
- 19.1 Eradication criteria
- 19.2 Credential reset/rebuild
- 19.3 Restore validation
- 19.4 Security verification
- 19.5 Business acceptance
- 19.6 Heightened monitoring

20 Post-Incident Review and Corrective Actions
- 20.1 Review trigger
- 20.2 Timeline reconstruction
- 20.3 Root-cause analysis
- 20.4 Control improvements
- 20.5 Action owners/dates
- 20.6 Lessons learned
- 20.7 Closure

21 Business Impact Analysis and Continuity Governance
- 21.1 Critical business services
- 21.2 Dependencies
- 21.3 Impact categories
- 21.4 Continuity owners
- 21.5 ContinuityHub records

22 Recovery Objectives and Service Prioritization
- 22.1 RTO
- 22.2 RPO
- 22.3 Recovery tiers
- 22.4 Dependency conflicts
- 22.5 Approved objective records
- 22.6 Objective exceptions

23 Business Continuity Scenario Procedures
- 23.1 Site unavailability
- 23.2 Workforce unavailability
- 23.3 Technology outage
- 23.4 Cloud/provider outage
- 23.5 Critical vendor failure
- 23.6 Cyberattack continuity
- 23.7 Utility/communications disruption

24 Disaster Recovery Coordination
- 24.1 DR invocation
- 24.2 Technology recovery teams
- 24.3 Data restore
- 24.4 Alternate environments
- 24.5 Security controls during DR
- 24.6 Return to primary

25 Exercises, Tests and Readiness
- 25.1 Tabletop exercises
- 25.2 Technical recovery tests
- 25.3 Communications tests
- 25.4 Vendor participation
- 25.5 Findings and remediation
- 25.6 Exercise evidence

26 Records, Metrics, Exceptions and Manual Maintenance
- 26.1 Incident records
- 26.2 Evidence access
- 26.3 Metrics
- 26.4 Continuity records
- 26.5 Procedure exceptions
- 26.6 Manual review

1 Purpose, Scope and Manual Authority

Security Incident Response & Business Continuity Manual | SEC-IR-004 | v5.2 | Effective 2026-08-01 | Section 1 Purpose, Scope and Manual Authority | Information Security & Resilience | CONFIDENTIAL

Purpose, Scope and Manual Authority establishes the requirements, responsibilities and decision rules that apply within this part of Security Incident Response & Business Continuity Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

1.1 Purpose

Purpose is governed as part of Purpose, Scope and Manual Authority. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For purpose, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

1.2 Incident types

Incident types is governed as part of Purpose, Scope and Manual Authority. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For incident, types, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

1.3 Business continuity events

Business continuity events is governed as part of Purpose, Scope and Manual Authority. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For business, continuity, events, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

1.4 Relationship to security policy

Relationship to security policy is governed as part of Purpose, Scope and Manual Authority. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For relationship, security, policy, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

1.5 No legal deadline inference

No legal deadline inference is governed as part of Purpose, Scope and Manual Authority. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For legal, deadline, inference, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

2 Incident Governance, Roles and Command Model

Security Incident Response & Business Continuity Manual | SEC-IR-004 | v5.2 | Effective 2026-08-01 | Section 2 Incident Governance, Roles and Command Model | Information Security & Resilience | CONFIDENTIAL

Incident Governance, Roles and Command Model establishes the requirements, responsibilities and decision rules that apply within this part of Security Incident Response & Business Continuity Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

2.1 SOC & Incident Response

SOC & Incident Response is governed as part of Incident Governance, Roles and Command Model. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For incident, response, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

2.2 Incident Commander

SEV-1 incidents and designated SEV-2 incidents use a named Incident Commander. The Major Incident Executive Group is activated for SEV-1 and selected SEV-2 events requiring enterprise coordination, client communications, continuity decisions or executive resources. Functional specialists retain authority for their domains while operating through the common incident command structure.

Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For incident, commander, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

SEC-IR-004-T03 - Incident Command RACI

Role	Accountability	Evidence
The	The Incident Commander coordinates overall response.	Workflow or controlled record
Technical leads execute cont	Technical leads execute containment and recovery within their domains.	Workflow or controlled record
Legal, Privacy, Communicatio	Legal, Privacy, Communications and Business Owners join when the facts require their authority.	Workflow or controlled record

2.3 CISO

CISO is governed as part of Incident Governance, Roles and Command Model. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For this activity, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

2.4 MIEG

MIEG is governed as part of Incident Governance, Roles and Command Model. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For this activity, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

2.5 System/Data/Business Owners

System/Data/Business Owners is governed as part of Incident Governance, Roles and Command Model. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For system, business, owners, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

2.6 DPO/Legal

DPO/Legal is governed as part of Incident Governance, Roles and Command Model. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For legal, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

Operational scenario S01: Active ransomware spreads across multiple managed endpoints. Apply the requirements in Security Incident Response & Business Continuity Manual to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.

2.7 Business Continuity

Business Continuity is governed as part of Incident Governance, Roles and Command Model. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For business, continuity, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

2.8 Communications

Communications is governed as part of Incident Governance, Roles and Command Model. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For communications, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

3 Severity Classification and Reclassification

Security Incident Response & Business Continuity Manual | SEC-IR-004 | v5.2 | Effective 2026-08-01 | Section 3 Severity Classification and Reclassification | Information Security & Resilience | CONFIDENTIAL

Severity Classification and Reclassification establishes the requirements, responsibilities and decision rules that apply within this part of Security Incident Response & Business Continuity Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

3.1 SEV-1 Critical

SEV-1 Critical is governed as part of Severity Classification and Reclassification. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For critical, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

3.2 SEV-2 High

SEV-2 High is governed as part of Severity Classification and Reclassification. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For this activity, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

SEC-IR-004-T01 - SEV-1 to SEV-4 Classification Matrix

Code	Class	Definition	Minimum handling
ADS-PUB	PUBLIC	Information approved for unrestricted external distribution by an authorized owner or publication process.	Integrity and authorized-publication controls; no assumption that all externally visible drafts are Public.
ADS-INT	INTERNAL	Default company information intended for Aurelius workforce use and not approved for public release.	Use company-approved systems; share externally only for legitimate business need and with appropriate authorization.
ADS-CONF	CONFIDENTIAL	Information whose unauthorized disclosure, alteration, or loss could materially harm Aurelius, a client, worker, or business relationship.	Need-to-know access; approved managed systems; encryption in transit and at rest where supported; controlled external sharing; enhanced logging where applicable.
ADS-REST	RESTRICTED	Highest internal protection level for information requiring tightly limited access because compromise could cause severe harm or enable material misuse.	Explicit authorized users; strongest available access controls; managed storage only; no public AI submission; no unmanaged removable media; specialist approval for external transfer.

3.3 SEV-3 Medium

SEV-3 Medium is governed as part of Severity Classification and Reclassification. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For medium, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

3.4 SEV-4 Low

SEV-4 Low is governed as part of Severity Classification and Reclassification. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For this activity, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

3.5 Potential impact

Potential impact is governed as part of Severity Classification and Reclassification. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For potential, impact, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

SEC-IR-004-T02 - Incident Response Target Matrix

Control point	Required treatment	Evidence
Business purpose	Must be defined before action or approval	Request/workflow record
Independent approval	No self-approval where requester benefits or is conflicted	Approval history
Specialist trigger	Route Security/Privacy/Legal/Finance/HR review when criteria apply	Concurrence record
Exception	Document scope, justification, controls and expiry	Approved exception record

3.6 Reclassification and audit trail

Incident severity uses the enterprise SEV-1 through SEV-4 definitions and internal response targets from the Canonical Registry. Severity reflects both actual and credible potential impact and may change as evidence changes. Reclassification must be time-stamped in the incident record with the reason and approving incident role.

Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For reclassification, audit, trail, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

4 Detection and Reporting

Security Incident Response & Business Continuity Manual | SEC-IR-004 | v5.2 | Effective 2026-08-01 | Section 4 Detection and Reporting | Information Security & Resilience | CONFIDENTIAL

Detection and Reporting establishes the requirements, responsibilities and decision rules that apply within this part of Security Incident Response & Business Continuity Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

4.1 Worker reporting

Worker reporting is governed as part of Detection and Reporting. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For worker, reporting, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

Related controlled source: Information Security Policy & Procedures Manual (SEC-POL-01) §18 - Worker security incident reporting duty. This reference supplements this section and does not transfer ownership of unrelated rules.

4.2 SignalWatch alerts

SignalWatch alerts is governed as part of Detection and Reporting. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For signalwatch, alerts, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

Operational scenario S02: Privileged identity infrastructure appears compromised. Apply the requirements in Security Incident Response & Business Continuity Manual to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.

4.3 EndpointShield alerts

EndpointShield alerts is governed as part of Detection and Reporting. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For endpointshield, alerts, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

4.4 DataGuard alerts

DataGuard alerts is governed as part of Detection and Reporting. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For dataguard, alerts, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

4.5 Vendor/client notifications

Vendor/client notifications is governed as part of Detection and Reporting. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For vendor, client, notifications, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

4.6 Out-of-band reporting

Out-of-band reporting is governed as part of Detection and Reporting. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For reporting, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

5 Initial Triage and Validation

Security Incident Response & Business Continuity Manual | SEC-IR-004 | v5.2 | Effective 2026-08-01 | Section 5 Initial Triage and Validation | Information Security & Resilience | CONFIDENTIAL

Initial Triage and Validation establishes the requirements, responsibilities and decision rules that apply within this part of Security Incident Response & Business Continuity Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

5.1 Intake

Intake is governed as part of Initial Triage and Validation. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For intake, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

5.2 Duplicate/event correlation

Duplicate/event correlation is governed as part of Initial Triage and Validation. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For duplicate, event, correlation, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

5.3 Scope estimation

Scope estimation is governed as part of Initial Triage and Validation. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For scope, estimation, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

5.4 Initial severity

Initial severity is governed as part of Initial Triage and Validation. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For initial, severity, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

5.5 Owner identification

Owner identification is governed as part of Initial Triage and Validation. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For owner, identification, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

Operational scenario S03: Employee reports entering credentials into a phishing page. Do not share credentials. Use AccessHub/KeyFort emergency or delegated-access procedures and report suspected compromise. Operational urgency changes the escalation path, not the requirement for individual accountability.

5.6 Immediate protective actions

Immediate protective actions is governed as part of Initial Triage and Validation. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For immediate, protective, actions, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

6 Incident Command and Escalation

Security Incident Response & Business Continuity Manual | SEC-IR-004 | v5.2 | Effective 2026-08-01 | Section 6 Incident Command and Escalation | Information Security & Resilience | CONFIDENTIAL

Incident Command and Escalation establishes the requirements, responsibilities and decision rules that apply within this part of Security Incident Response & Business Continuity Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

6.1 Command activation

Command activation is governed as part of Incident Command and Escalation. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For command, activation, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

6.2 MIEG activation

MIEG activation is governed as part of Incident Command and Escalation. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For activation, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

6.3 Executive escalation

SEV-1 incidents and designated SEV-2 incidents use a named Incident Commander. The Major Incident Executive Group is activated for SEV-1 and selected SEV-2 events requiring enterprise coordination, client communications, continuity decisions or executive resources. Functional specialists retain authority for their domains while operating through the common incident command structure.

Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For executive, escalation, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

6.4 Specialist concurrence

Specialist concurrence is governed as part of Incident Command and Escalation. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For specialist, concurrence, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

6.5 Shift handover

Shift handover is governed as part of Incident Command and Escalation. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For shift, handover, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

6.6 Decision log

Decision log is governed as part of Incident Command and Escalation. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For decision, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

7 Containment Strategy and Emergency Change Control

Security Incident Response & Business Continuity Manual | SEC-IR-004 | v5.2 | Effective 2026-08-01 | Section 7 Containment Strategy and Emergency Change Control | Information Security & Resilience | CONFIDENTIAL

Containment Strategy and Emergency Change Control establishes the requirements, responsibilities and decision rules that apply within this part of Security Incident Response & Business Continuity Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

7.1 Containment objectives

Containment must reduce immediate risk without unnecessarily destroying evidence or creating uncontrolled business impact. Emergency changes are recorded retrospectively when pre-approval is impossible. Identity containment, network isolation, token revocation, vendor suspension and workload shutdown are selected according to the threat and service criticality.

Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For containment, objectives, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

7.2 Account containment

Containment must reduce immediate risk without unnecessarily destroying evidence or creating uncontrolled business impact. Emergency changes are recorded retrospectively when pre-approval is impossible. Identity containment, network isolation, token revocation, vendor suspension and workload shutdown are selected according to the threat and service criticality.

Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For account, containment, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

SEC-IR-004-T04 - Containment Decision Matrix

Situation	Primary approver	Specialist concurrence	Evidence
Routine request	Line Manager / designated owner	As triggered	Business purpose + workflow record
Material or high-risk request	Functional Head / Business Owner	Security/Privacy/Legal/Finance as applicable	Risk and exception rationale
Enterprise exception	Executive Approver or governance committee	Policy Owner	Scope, conditions, expiry, review date

Operational scenario S04: Single endpoint malware is contained by EndpointShield. Apply the requirements in Security Incident Response & Business Continuity Manual to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.

7.3 Endpoint containment

Containment must reduce immediate risk without unnecessarily destroying evidence or creating uncontrolled business impact. Emergency changes are recorded retrospectively when pre-approval is impossible. Identity containment, network isolation, token revocation, vendor suspension and workload shutdown are selected according to the threat and service criticality.

Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For endpoint, containment, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

7.4 Network/cloud containment

Containment must reduce immediate risk without unnecessarily destroying evidence or creating uncontrolled business impact. Emergency changes are recorded retrospectively when pre-approval is impossible. Identity containment, network isolation, token revocation, vendor suspension and workload shutdown are selected according to the threat and service criticality.

Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For network, cloud, containment, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

7.5 Data movement containment

Containment must reduce immediate risk without unnecessarily destroying evidence or creating uncontrolled business impact. Emergency changes are recorded retrospectively when pre-approval is impossible. Identity containment, network isolation, token revocation, vendor suspension and workload shutdown are selected according to the threat and service criticality.

Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For movement, containment, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

7.6 Business impact trade-offs

Business impact trade-offs is governed as part of Containment Strategy and Emergency Change Control. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For business, impact, trade, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

7.7 Emergency change evidence

Emergency change evidence is governed as part of Containment Strategy and Emergency Change Control. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For emergency, change, evidence, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

8 Credential Compromise and Identity Incidents

Security Incident Response & Business Continuity Manual | SEC-IR-004 | v5.2 | Effective 2026-08-01 | Section 8 Credential Compromise and Identity Incidents | Information Security & Resilience | CONFIDENTIAL

Credential Compromise and Identity Incidents establishes the requirements, responsibilities and decision rules that apply within this part of Security Incident Response & Business Continuity Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

8.1 User credential compromise

User credential compromise is governed as part of Credential Compromise and Identity Incidents. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For credential, compromise, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

8.2 Privileged compromise

Privileged compromise is governed as part of Credential Compromise and Identity Incidents. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For privileged, compromise, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

SEC-IR-004-T05 - Credential Compromise Response Matrix

Control point	Required treatment	Evidence
Business purpose	Must be defined before action or approval	Request/workflow record
Independent approval	No self-approval where requester benefits or is conflicted	Approval history
Specialist trigger	Route Security/Privacy/Legal/Finance/HR review when criteria apply	Concurrence record
Exception	Document scope, justification, controls and expiry	Approved exception record

8.3 Service account/API key compromise

Service account/API key compromise is governed as part of Credential Compromise and Identity Incidents. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For service, account, compromise, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

Operational scenario S05: Employee sends CONFIDENTIAL personal data to an unauthorized internal recipient. Apply the requirements in Security Incident Response & Business Continuity Manual to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.

8.4 MFA bypass

MFA bypass is governed as part of Credential Compromise and Identity Incidents. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For bypass, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

8.5 Session/token revocation

Session/token revocation is governed as part of Credential Compromise and Identity Incidents. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For session, token, revocation, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

8.6 Recovery and recertification

Recovery and recertification is governed as part of Credential Compromise and Identity Incidents. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For recovery, recertification, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

Related controlled source: Identity, Access Management & Acceptable Technology Use Standard (IAM-STD-03) §12 - Account recovery and emergency access. This reference supplements this section and does not transfer ownership of unrelated rules.

9 Phishing, Business Email and Messaging Incidents

Security Incident Response & Business Continuity Manual | SEC-IR-004 | v5.2 | Effective 2026-08-01 | Section 9 Phishing, Business Email and Messaging Incidents | Information Security & Resilience | CONFIDENTIAL

Phishing, Business Email and Messaging Incidents establishes the requirements, responsibilities and decision rules that apply within this part of Security Incident Response & Business Continuity Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

9.1 Reported phishing

Reported phishing is governed as part of Phishing, Business Email and Messaging Incidents. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For reported, phishing, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

9.2 Clicked link/attachment

Clicked link/attachment is governed as part of Phishing, Business Email and Messaging Incidents. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For clicked, attachment, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

9.3 Credential submission

Credential submission is governed as part of Phishing, Business Email and Messaging Incidents. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For credential, submission, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

9.4 Mailbox rule abuse

Mailbox rule abuse is governed as part of Phishing, Business Email and Messaging Incidents. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For mailbox, abuse, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

9.5 Internal propagation

Internal propagation is governed as part of Phishing, Business Email and Messaging Incidents. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For internal, propagation, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

Operational scenario S06: Corporate laptop is lost during travel. Apply the requirements in Security Incident Response & Business Continuity Manual to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.

9.6 Payment-fraud coordination

Payment-fraud coordination is governed as part of Phishing, Business Email and Messaging Incidents. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For payment, fraud, coordination, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

10 Malware and Ransomware

Security Incident Response & Business Continuity Manual | SEC-IR-004 | v5.2 | Effective 2026-08-01 | Section 10 Malware and Ransomware | Information Security & Resilience | CONFIDENTIAL

Malware and Ransomware establishes the requirements, responsibilities and decision rules that apply within this part of Security Incident Response & Business Continuity Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

10.1 Single endpoint malware

Single endpoint malware is governed as part of Malware and Ransomware. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For single, endpoint, malware, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

10.2 Multi-endpoint outbreak

Multi-endpoint outbreak is governed as part of Malware and Ransomware. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For multi, endpoint, outbreak, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

10.3 Ransomware indicators

Ransomware indicators is governed as part of Malware and Ransomware. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For ransomware, indicators, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

10.4 Isolation

Isolation is governed as part of Malware and Ransomware. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For isolation, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

10.5 Destructive activity

Destructive activity is governed as part of Malware and Ransomware. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For destructive, activity, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

10.6 Recovery decision

Recovery decision is governed as part of Malware and Ransomware. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For recovery, decision, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

10.7 Extortion-contact boundary

Extortion-contact boundary is governed as part of Malware and Ransomware. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For extortion, contact, boundary, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

11 Lost, Stolen or Unaccounted Devices

Security Incident Response & Business Continuity Manual | SEC-IR-004 | v5.2 | Effective 2026-08-01 | Section 11 Lost, Stolen or Unaccounted Devices | Information Security & Resilience | CONFIDENTIAL

Lost, Stolen or Unaccounted Devices establishes the requirements, responsibilities and decision rules that apply within this part of Security Incident Response & Business Continuity Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

11.1 Immediate report

Immediate report is governed as part of Lost, Stolen or Unaccounted Devices. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For immediate, report, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

11.2 DeviceCentral actions

DeviceCentral actions is governed as part of Lost, Stolen or Unaccounted Devices. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For devicecentral, actions, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

Operational scenario S07: Cloud storage bucket is discovered publicly accessible. Apply the requirements in Security Incident Response & Business Continuity Manual to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.

11.3 Access/session containment

Containment must reduce immediate risk without unnecessarily destroying evidence or creating uncontrolled business impact. Emergency changes are recorded retrospectively when pre-approval is impossible. Identity containment, network isolation, token revocation, vendor suspension and workload shutdown are selected according to the threat and service criticality.

Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For access, session, containment, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

11.4 Data exposure assessment

Data exposure assessment is governed as part of Lost, Stolen or Unaccounted Devices. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For exposure, assessment, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

11.5 AssetSphere update

AssetSphere update is governed as part of Lost, Stolen or Unaccounted Devices. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For assetsphere, update, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

11.6 Travel-related loss

Travel-related loss is governed as part of Lost, Stolen or Unaccounted Devices. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For travel, related, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

12 Data Exposure and Privacy Incidents

Security Incident Response & Business Continuity Manual | SEC-IR-004 | v5.2 | Effective 2026-08-01 | Section 12 Data Exposure and Privacy Incidents | Information Security & Resilience | CONFIDENTIAL

Data Exposure and Privacy Incidents establishes the requirements, responsibilities and decision rules that apply within this part of Security Incident Response & Business Continuity Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

12.1 Wrong-recipient disclosure

Wrong-recipient disclosure is governed as part of Data Exposure and Privacy Incidents. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For wrong, recipient, disclosure, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

12.2 Public exposure

Public exposure is governed as part of Data Exposure and Privacy Incidents. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For public, exposure, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

SEC-IR-004-T06 - Privacy/Security Incident Coordination Matrix

Control point	Required treatment	Evidence
Business purpose	Must be defined before action or approval	Request/workflow record
Independent approval	No self-approval where requester benefits or is conflicted	Approval history
Specialist trigger	Route Security/Privacy/Legal/Finance/HR review when criteria apply	Concurrence record
Exception	Document scope, justification, controls and expiry	Approved exception record

12.3 Bulk data loss

Bulk data loss is governed as part of Data Exposure and Privacy Incidents. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For this activity, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

12.4 Privacy Incident assessment

Privacy Incident assessment is governed as part of Data Exposure and Privacy Incidents. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For privacy, incident, assessment, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

Related controlled source: Data Privacy & Data Governance Policy (PRIV-DG-02) §16 - Privacy Incident assessment. This reference supplements this section and does not transfer ownership of unrelated rules.

12.5 DPO coordination

DPO coordination is governed as part of Data Exposure and Privacy Incidents. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For coordination, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

Operational scenario S08: Vendor reports breach affecting an Aurelius integration. Apply the requirements in Security Incident Response & Business Continuity Manual to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.

12.6 External notification decision reserved to verified Legal/DPO process

External notification decision reserved to verified Legal/DPO process is governed as part of Data Exposure and Privacy Incidents. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For external, notification, decision, reserved, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

13 Cloud, SaaS and Infrastructure Incidents

Cloud, SaaS and Infrastructure Incidents establishes the requirements, responsibilities and decision rules that apply within this part of Security Incident Response & Business Continuity Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

13.1 Compromised cloud identity

Compromised cloud identity is governed as part of Cloud, SaaS and Infrastructure Incidents. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For compromised, cloud, identity, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

13.2 Misconfiguration exposure

Misconfiguration exposure is governed as part of Cloud, SaaS and Infrastructure Incidents. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For misconfiguration, exposure, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

13.3 Malicious API activity

Malicious API activity is governed as part of Cloud, SaaS and Infrastructure Incidents. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For malicious, activity, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

13.4 SaaS tenant incident

SaaS tenant incident is governed as part of Cloud, SaaS and Infrastructure Incidents. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For tenant, incident, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

13.5 Cloud service outage

Cloud service outage is governed as part of Cloud, SaaS and Infrastructure Incidents. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For cloud, service, outage, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

13.6 Provider escalation

SEV-1 incidents and designated SEV-2 incidents use a named Incident Commander. The Major Incident Executive Group is activated for SEV-1 and selected SEV-2 events requiring enterprise coordination, client communications, continuity decisions or executive resources. Functional specialists retain authority for their domains while operating through the common incident command structure.

Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For provider, escalation, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

Operational scenario S09: Contractor leaves unexpectedly and suspicious access continues. The sponsor triggers the departure immediately; IAM suspends access under IAM-STD-03; Vendor Management coordinates the supplier action; Security is engaged if the departure is unexplained or suspicious. Client-data access is not left active merely because paperwork is incomplete.

14 Insider Threat and Suspicious Internal Activity

Security Incident Response & Business Continuity Manual | SEC-IR-004 | v5.2 | Effective 2026-08-01 | Section 14 Insider Threat and Suspicious Internal Activity | Information Security & Resilience | CONFIDENTIAL

Insider Threat and Suspicious Internal Activity establishes the requirements, responsibilities and decision rules that apply within this part of Security Incident Response & Business Continuity Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

14.1 Initial handling

Initial handling is governed as part of Insider Threat and Suspicious Internal Activity. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For initial, handling, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

14.2 Need-to-know investigation

Need-to-know investigation is governed as part of Insider Threat and Suspicious Internal Activity. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For investigation, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

14.3 Evidence preservation

Evidence preservation is governed as part of Insider Threat and Suspicious Internal Activity. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For evidence, preservation, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

14.4 HR/Legal coordination

HR/Legal coordination is governed as part of Insider Threat and Suspicious Internal Activity. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For legal, coordination, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

14.5 Access containment

Containment must reduce immediate risk without unnecessarily destroying evidence or creating uncontrolled business impact. Emergency changes are recorded retrospectively when pre-approval is impossible. Identity containment, network isolation, token revocation, vendor suspension and workload shutdown are selected according to the threat and service criticality.

Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For access, containment, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

14.6 Avoiding premature conclusions

Avoiding premature conclusions is governed as part of Insider Threat and Suspicious Internal Activity. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For avoiding, premature, conclusions, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

15 Vendor and Third-Party Incidents

Security Incident Response & Business Continuity Manual | SEC-IR-004 | v5.2 | Effective 2026-08-01 | Section 15 Vendor and Third-Party Incidents | Information Security & Resilience | CONFIDENTIAL

Vendor and Third-Party Incidents establishes the requirements, responsibilities and decision rules that apply within this part of Security Incident Response & Business Continuity Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

15.1 Vendor notification intake

Vendor notification intake is governed as part of Vendor and Third-Party Incidents. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For vendor, notification, intake, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

15.2 Critical Vendor prioritization

Critical Vendor prioritization is governed as part of Vendor and Third-Party Incidents. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For critical, vendor, prioritization, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

SEC-IR-004-T07 - Vendor Incident Escalation Matrix

Control point	Required treatment	Evidence
Business purpose	Must be defined before action or approval	Request/workflow record
Independent approval	No self-approval where requester benefits or is conflicted	Approval history
Specialist trigger	Route Security/Privacy/Legal/Finance/HR review when criteria apply	Concurrence record
Exception	Document scope, justification, controls and expiry	Approved exception record

15.3 Access containment

Containment must reduce immediate risk without unnecessarily destroying evidence or creating uncontrolled business impact. Emergency changes are recorded retrospectively when pre-approval is impossible. Identity containment, network isolation, token revocation, vendor suspension and workload shutdown are selected according to the threat and service criticality.

Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For access, containment, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

Operational scenario S10: Public LLM receives customer data by mistake. Stop further submission, preserve the relevant details, notify the Security Operations Centre and Privacy where personal/client data may be involved, and follow AI-GOV-05 for use-case/tool review. Do not attempt to erase evidence by altering logs or accounts.

15.4 Contract/procurement coordination

Contract/procurement coordination is governed as part of Vendor and Third-Party Incidents. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For contract, procurement, coordination, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

Related controlled source: Procurement, Vendor & Third-Party Risk Management Policy (PROC-TPRM-11) §17 - Vendor incident governance. This reference supplements this section and does not transfer ownership of unrelated rules.

15.5 Evidence and assurance requests

Evidence and assurance requests is governed as part of Vendor and Third-Party Incidents. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For evidence, assurance, requests, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

15.6 Service continuity

Service continuity is governed as part of Vendor and Third-Party Incidents. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For service, continuity, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

16 AI, Model, RAG and Agent Incidents

Security Incident Response & Business Continuity Manual | SEC-IR-004 | v5.2 | Effective 2026-08-01 | Section 16 AI, Model, RAG and Agent Incidents | Information Security & Resilience | CONFIDENTIAL

AI, Model, RAG and Agent Incidents establishes the requirements, responsibilities and decision rules that apply within this part of Security Incident Response & Business Continuity Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

16.1 Sensitive data submitted to AI

Sensitive data submitted to AI is governed as part of AI, Model, RAG and Agent Incidents. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For sensitive, submitted, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

16.2 Prompt injection/indirect instruction

Prompt injection/indirect instruction is governed as part of AI, Model, RAG and Agent Incidents. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For prompt, injection, indirect, instruction, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

SEC-IR-004-T08 - AI Incident Decision Matrix

Situation	Primary approver	Specialist concurrence	Evidence
Routine request	Line Manager / designated owner	As triggered	Business purpose + workflow record
Material or high-risk request	Functional Head / Business Owner	Security/Privacy/Legal/Finance as applicable	Risk and exception rationale
Enterprise exception	Executive Approver or governance committee	Policy Owner	Scope, conditions, expiry, review date

16.3 Model/API credential compromise

Model/API credential compromise is governed as part of AI, Model, RAG and Agent Incidents. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For model, credential, compromise, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

16.4 Unsafe agent action

Unsafe agent action is governed as part of AI, Model, RAG and Agent Incidents. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For unsafe, agent, action, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

16.5 RAG data exposure

RAG data exposure is governed as part of AI, Model, RAG and Agent Incidents. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For exposure, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

16.6 Model integrity concern

Model integrity concern is governed as part of AI, Model, RAG and Agent Incidents. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For model, integrity, concern, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

16.7 AI governance coordination

AI governance coordination is governed as part of AI, Model, RAG and Agent Incidents. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For governance, coordination, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

Related controlled source: AI, Machine Learning & Generative AI Governance Standard (AI-GOV-05) §22 - AI incident governance. This reference supplements this section and does not transfer ownership of unrelated rules.

Operational scenario S11: AI agent executes an unintended production change. Apply the requirements in Security Incident Response & Business Continuity Manual to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.

17 Evidence Preservation and Investigation

Security Incident Response & Business Continuity Manual | SEC-IR-004 | v5.2 | Effective 2026-08-01 | Section 17 Evidence Preservation and Investigation | Information Security & Resilience | CONFIDENTIAL

Evidence Preservation and Investigation establishes the requirements, responsibilities and decision rules that apply within this part of Security Incident Response & Business Continuity Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

17.1 Evidence principles

Evidence principles is governed as part of Evidence Preservation and Investigation. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For evidence, principles, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

17.2 Log preservation

Log preservation is governed as part of Evidence Preservation and Investigation. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For preservation, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

17.3 Endpoint/cloud evidence

Endpoint/cloud evidence is governed as part of Evidence Preservation and Investigation. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For endpoint, cloud, evidence, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

17.4 Chain-of-custody style internal record

Chain-of-custody style internal record is governed as part of Evidence Preservation and Investigation. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For chain, custody, style, internal, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

17.5 Interviews

Interviews is governed as part of Evidence Preservation and Investigation. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For interviews, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

17.6 Access to evidence

Access to evidence is governed as part of Evidence Preservation and Investigation. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For access, evidence, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

17.7 Third-party evidence

Third-party evidence is governed as part of Evidence Preservation and Investigation. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For third, party, evidence, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

18 Incident Communications

Security Incident Response & Business Continuity Manual | SEC-IR-004 | v5.2 | Effective 2026-08-01 | Section 18 Incident Communications | Information Security & Resilience | CONFIDENTIAL

Incident Communications establishes the requirements, responsibilities and decision rules that apply within this part of Security Incident Response & Business Continuity Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

18.1 Internal updates

Internal updates is governed as part of Incident Communications. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For internal, updates, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

18.2 Executive updates

Executive updates is governed as part of Incident Communications. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For executive, updates, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

SEC-IR-004-T09 - Communication Approval Matrix

Situation	Primary approver	Specialist concurrence	Evidence
Routine request	Line Manager / designated owner	As triggered	Business purpose + workflow record
Material or high-risk request	Functional Head / Business Owner	Security/Privacy/Legal/Finance as applicable	Risk and exception rationale
Enterprise exception	Executive Approver or governance committee	Policy Owner	Scope, conditions, expiry, review date
Operational scenario S12: RAG system exposes content a user was not authorized to retrieve. Apply the requirements in Security Incident Response & Business Continuity Manual to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.			

18.3 Client communications

Client communications is governed as part of Incident Communications. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For client, communications, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

18.4 Employee communications

Employee communications is governed as part of Incident Communications. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For employee, communications, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

18.5 Media/public communications

Media/public communications is governed as part of Incident Communications. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For media, public, communications, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

18.6 Communication approvals

Communication approvals is governed as part of Incident Communications. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For communication, approvals, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

19 Eradication, Recovery and Return to Service

Security Incident Response & Business Continuity Manual | SEC-IR-004 | v5.2 | Effective 2026-08-01 | Section 19 Eradication, Recovery and Return to Service | Information Security & Resilience | CONFIDENTIAL

Eradication, Recovery and Return to Service establishes the requirements, responsibilities and decision rules that apply within this part of Security Incident Response & Business Continuity Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

19.1 Eradication criteria

Eradication criteria is governed as part of Eradication, Recovery and Return to Service. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For eradication, criteria, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

19.2 Credential reset/rebuild

Credential reset/rebuild is governed as part of Eradication, Recovery and Return to Service. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For credential, reset, rebuild, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

SEC-IR-004-T10 - Recovery Entry/Exit Criteria

Service tier	RTO	RPO	Use
Tier 1	4h	1h	Critical business/client service
Tier 2	12h	4h	Important service
Tier 3	48h	24h	Standard service
Tier 4	Up to 5 business days	Up to 48h	Low-criticality/best effort

19.3 Restore validation

SOCIR validates the report, identifies affected identities/assets/data, establishes a working timeline, checks for continuing attacker or failure activity and assigns provisional severity. Triage should preserve evidence; responders should not wipe, rebuild or reset affected systems until containment and evidence needs are understood unless immediate action is required to prevent material harm.

Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For restore, validation, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

19.4 Security verification

Security verification is governed as part of Eradication, Recovery and Return to Service. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For security, verification, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

19.5 Business acceptance

Business acceptance is governed as part of Eradication, Recovery and Return to Service. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For business, acceptance, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

Operational scenario S13: Major SaaS provider outage disrupts client support. Apply the requirements in Security Incident Response & Business Continuity Manual to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.

19.6 Heightened monitoring

Heightened monitoring is governed as part of Eradication, Recovery and Return to Service. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For heightened, monitoring, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

20 Post-Incident Review and Corrective Actions

Security Incident Response & Business Continuity Manual | SEC-IR-004 | v5.2 | Effective 2026-08-01 | Section 20 Post-Incident Review and Corrective Actions | Information Security & Resilience | CONFIDENTIAL

Post-Incident Review and Corrective Actions establishes the requirements, responsibilities and decision rules that apply within this part of Security Incident Response & Business Continuity Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

20.1 Review trigger

Review trigger is governed as part of Post-Incident Review and Corrective Actions. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For review, trigger, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

20.2 Timeline reconstruction

Timeline reconstruction is governed as part of Post-Incident Review and Corrective Actions. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For timeline, reconstruction, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

20.3 Root-cause analysis

Root-cause analysis is governed as part of Post-Incident Review and Corrective Actions. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For cause, analysis, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

20.4 Control improvements

Control improvements is governed as part of Post-Incident Review and Corrective Actions. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For control, improvements, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

20.5 Action owners/dates

Action owners/dates is governed as part of Post-Incident Review and Corrective Actions. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For action, owners, dates, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

20.6 Lessons learned

Lessons learned is governed as part of Post-Incident Review and Corrective Actions. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For lessons, learned, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

20.7 Closure

Closure is governed as part of Post-Incident Review and Corrective Actions. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For closure, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

21 Business Impact Analysis and Continuity Governance

Security Incident Response & Business Continuity Manual | SEC-IR-004 | v5.2 | Effective 2026-08-01 | Section 21 Business Impact Analysis and Continuity Governance | Information Security & Resilience | CONFIDENTIAL

Business Impact Analysis and Continuity Governance establishes the requirements, responsibilities and decision rules that apply within this part of Security Incident Response & Business Continuity Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

21.1 Critical business services

Critical business services is governed as part of Business Impact Analysis and Continuity Governance. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For critical, business, services, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

21.2 Dependencies

Dependencies is governed as part of Business Impact Analysis and Continuity Governance. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For dependencies, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

Operational scenario S14: Bengaluru headquarters becomes temporarily unavailable. Apply the requirements in Security Incident Response & Business Continuity Manual to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.

21.3 Impact categories

Impact categories is governed as part of Business Impact Analysis and Continuity Governance. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For impact, categories, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

21.4 Continuity owners

Continuity owners is governed as part of Business Impact Analysis and Continuity Governance. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For continuity, owners, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

21.5 ContinuityHub records

ContinuityHub records is governed as part of Business Impact Analysis and Continuity Governance. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For continuityhub, records, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

22 Recovery Objectives and Service Prioritization

Security Incident Response & Business Continuity Manual | SEC-IR-004 | v5.2 | Effective 2026-08-01 | Section 22 Recovery Objectives and Service Prioritization | Information Security & Resilience | CONFIDENTIAL

Recovery Objectives and Service Prioritization establishes the requirements, responsibilities and decision rules that apply within this part of Security Incident Response & Business Continuity Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

22.1 RTO

RTO is governed as part of Recovery Objectives and Service Prioritization. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For this activity, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

22.2 RPO

RPO is governed as part of Recovery Objectives and Service Prioritization. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For this activity, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

SEC-IR-004-T11 - Business Service Recovery Tier Matrix

Service tier	RTO	RPO	Use
Tier 1	4h	1h	Critical business/client service
Tier 2	12h	4h	Important service
Tier 3	48h	24h	Standard service
Tier 4	Up to 5 business days	Up to 48h	Low-criticality/best effort

22.3 Recovery tiers

Recovery tiers is governed as part of Recovery Objectives and Service Prioritization. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For recovery, tiers, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

22.4 Dependency conflicts

Dependency conflicts is governed as part of Recovery Objectives and Service Prioritization. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For dependency, conflicts, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

22.5 Approved objective records

Approved objective records is governed as part of Recovery Objectives and Service Prioritization. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For approved, objective, records, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

Related controlled source: Information Security Policy & Procedures Manual (SEC-POL-01) §11 - Backup/recovery controls. This reference supplements this section and does not transfer ownership of unrelated rules.

Operational scenario S15: Critical vendor outage threatens a recovery dependency. Apply the requirements in Security Incident Response & Business Continuity Manual to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.

22.6 Objective exceptions

Objective exceptions is governed as part of Recovery Objectives and Service Prioritization. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For objective, exceptions, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

23 Business Continuity Scenario Procedures

Security Incident Response & Business Continuity Manual | SEC-IR-004 | v5.2 | Effective 2026-08-01 | Section 23 Business Continuity Scenario Procedures | Information Security & Resilience | CONFIDENTIAL

Business Continuity Scenario Procedures establishes the requirements, responsibilities and decision rules that apply within this part of Security Incident Response & Business Continuity Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

23.1 Site unavailability

Site unavailability is governed as part of Business Continuity Scenario Procedures. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For unavailability, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

23.2 Workforce unavailability

Workforce unavailability is governed as part of Business Continuity Scenario Procedures. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For workforce, unavailability, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

SEC-IR-004-T12 - Continuity Scenario Activation Matrix

Service tier	RTO	RPO	Use
Tier 1	4h	1h	Critical business/client service
Tier 2	12h	4h	Important service
Tier 3	48h	24h	Standard service
Tier 4	Up to 5 business days	Up to 48h	Low-criticality/best effort

23.3 Technology outage

Technology outage is governed as part of Business Continuity Scenario Procedures. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For technology, outage, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

23.4 Cloud/provider outage

Cloud/provider outage is governed as part of Business Continuity Scenario Procedures. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For cloud, provider, outage, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

23.5 Critical vendor failure

Critical vendor failure is governed as part of Business Continuity Scenario Procedures. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For critical, vendor, failure, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

23.6 Cyberattack continuity

Cyberattack continuity is governed as part of Business Continuity Scenario Procedures. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For cyberattack, continuity, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

23.7 Utility/communications disruption

Utility/communications disruption is governed as part of Business Continuity Scenario Procedures. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For utility, communications, disruption, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

Operational scenario S16: Incident severity changes from SEV-3 to SEV-2 as data exposure is confirmed. Apply the requirements in Security Incident Response & Business Continuity Manual to the facts, confirm the relevant source-of-truth record and route any specialist issue to the controlling document or function. If a required fact is missing, do not invent it; obtain the controlled record or specialist decision.

24 Disaster Recovery Coordination

Security Incident Response & Business Continuity Manual | SEC-IR-004 | v5.2 | Effective 2026-08-01 | Section 24 Disaster Recovery Coordination | Information Security & Resilience | CONFIDENTIAL

Disaster Recovery Coordination establishes the requirements, responsibilities and decision rules that apply within this part of Security Incident Response & Business Continuity Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

24.1 DR invocation

DR invocation is governed as part of Disaster Recovery Coordination. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For invocation, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

24.2 Technology recovery teams

Technology recovery teams is governed as part of Disaster Recovery Coordination. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For technology, recovery, teams, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

24.3 Data restore

Data restore is governed as part of Disaster Recovery Coordination. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For restore, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

24.4 Alternate environments

Alternate environments is governed as part of Disaster Recovery Coordination. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For alternate, environments, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

24.5 Security controls during DR

Security controls during DR is governed as part of Disaster Recovery Coordination. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For security, controls, during, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

24.6 Return to primary

Return to primary is governed as part of Disaster Recovery Coordination. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For return, primary, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

25 Exercises, Tests and Readiness

Security Incident Response & Business Continuity Manual | SEC-IR-004 | v5.2 | Effective 2026-08-01 | Section 25 Exercises, Tests and Readiness | Information Security & Resilience | CONFIDENTIAL

Exercises, Tests and Readiness establishes the requirements, responsibilities and decision rules that apply within this part of Security Incident Response & Business Continuity Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

25.1 Tabletop exercises

Tier 1 services participate in at least one continuity or recovery exercise each year and a major-incident tabletop each quarter at the enterprise programme level. Exercises must record assumptions, observed control gaps, owners and target dates; an exercise is not closed merely because the scenario discussion completed.

Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For tabletop, exercises, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

25.2 Technical recovery tests

Technical recovery tests is governed as part of Exercises, Tests and Readiness. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For technical, recovery, tests, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

SEC-IR-004-T13 - Exercise/Test Programme Matrix

Control point	Required treatment	Evidence
Business purpose	Must be defined before action or approval	Request/workflow record
Independent approval	No self-approval where requester benefits or is conflicted	Approval history
Specialist trigger	Route Security/Privacy/Legal/Finance/HR review when criteria apply	Concurrence record
Exception	Document scope, justification, controls and expiry	Approved exception record

25.3 Communications tests

Communications tests is governed as part of Exercises, Tests and Readiness. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For communications, tests, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

25.4 Vendor participation

Vendor participation is governed as part of Exercises, Tests and Readiness. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For vendor, participation, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

25.5 Findings and remediation

Findings and remediation is governed as part of Exercises, Tests and Readiness. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For findings, remediation, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

25.6 Exercise evidence

Exercise evidence is governed as part of Exercises, Tests and Readiness. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For exercise, evidence, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

26 Records, Metrics, Exceptions and Manual Maintenance

Security Incident Response & Business Continuity Manual | SEC-IR-004 | v5.2 | Effective 2026-08-01 | Section 26 Records, Metrics, Exceptions and Manual Maintenance | Information Security & Resilience | CONFIDENTIAL

Records, Metrics, Exceptions and Manual Maintenance establishes the requirements, responsibilities and decision rules that apply within this part of Security Incident Response & Business Continuity Manual. The rules are interpreted with the document scope, the employee/worker or system context, and any specialist cross-reference that applies.

26.1 Incident records

Incident records is governed as part of Records, Metrics, Exceptions and Manual Maintenance. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For incident, records, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

26.2 Evidence access

Evidence access is governed as part of Records, Metrics, Exceptions and Manual Maintenance. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For evidence, access, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

26.3 Metrics

Metrics is governed as part of Records, Metrics, Exceptions and Manual Maintenance. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For metrics, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

26.4 Continuity records

Continuity records is governed as part of Records, Metrics, Exceptions and Manual Maintenance. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For continuity, records, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

26.5 Procedure exceptions

Procedure exceptions is governed as part of Records, Metrics, Exceptions and Manual Maintenance. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For procedure, exceptions, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

26.6 Manual review

Manual review is governed as part of Records, Metrics, Exceptions and Manual Maintenance. Responders prioritize safety, containment, evidence preservation and restoration of business services according to the best available facts.

For manual, review, responders use the least disruptive action that achieves containment or recovery while preserving necessary evidence. Incident actions, decisions, severity changes and exceptions are recorded in the designated incident record so that response remains coordinated and reviewable.

- Record the time, actor, action, affected assets and reason for material response decisions.
- Reassess severity and business impact whenever new evidence materially changes the working hypothesis.
- Escalate specialist decisions to the function that owns them rather than making legal, privacy or client commitments inside the technical response team.

Appendices, Forms and Checklists

Security Incident Response & Business Continuity Manual | SEC-IR-004 | v5.2 | Effective 2026-08-01 | Section Appendices Controlled execution aids | Information Security & Resilience | CONFIDENTIAL

SEC-IR-004-AA Incident Contact and Escalation Matrix

Contact	Purpose
security@aureliusdigital.example	Security governance questions, control guidance, and non-urgent security concerns
soc@aureliusdigital.example	Security incident and suspected compromise reporting; monitored 24x7
phishing@aureliusdigital.example	Suspected phishing and malicious-message reporting
bcm@aureliusdigital.example	Business continuity planning and exercise coordination

SEC-IR-004-AB Incident Commander Checklist

Use this checklist as an execution aid. It does not create an exception or replace an approval required by the controlling section.

- Confirm the request or event is within the scope of Security Incident Response & Business Continuity Manual.
- Verify the authoritative worker, system, vendor, expense, incident or model record before taking action.
- Identify conditions that change the rule, including employment category, band, data classification, risk level, location, client assignment or service criticality.
- Obtain independent approval and specialist concurrence where the policy requires it.
- Record the decision, evidence, exception conditions and any expiry or follow-up date in the designated system.
- Escalate unresolved conflicts to the Policy Owner rather than creating a local workaround.

Appendices - continued

SEC-IR-004-AC Evidence Preservation Checklist

Use this checklist as an execution aid. It does not create an exception or replace an approval required by the controlling section.

- Confirm the request or event is within the scope of Security Incident Response & Business Continuity Manual.
- Verify the authoritative worker, system, vendor, expense, incident or model record before taking action.
- Identify conditions that change the rule, including employment category, band, data classification, risk level, location, client assignment or service criticality.
- Obtain independent approval and specialist concurrence where the policy requires it.
- Record the decision, evidence, exception conditions and any expiry or follow-up date in the designated system.
- Escalate unresolved conflicts to the Policy Owner rather than creating a local workaround.

SEC-IR-004-AD Ransomware Decision Tree

Use this checklist as an execution aid. It does not create an exception or replace an approval required by the controlling section.

- Confirm the request or event is within the scope of Security Incident Response & Business Continuity Manual.
- Verify the authoritative worker, system, vendor, expense, incident or model record before taking action.
- Identify conditions that change the rule, including employment category, band, data classification, risk level, location, client assignment or service criticality.
- Obtain independent approval and specialist concurrence where the policy requires it.
- Record the decision, evidence, exception conditions and any expiry or follow-up date in the designated system.
- Escalate unresolved conflicts to the Policy Owner rather than creating a local workaround.

Appendices - continued

SEC-IR-004-AE Credential Compromise Decision Tree

Use this checklist as an execution aid. It does not create an exception or replace an approval required by the controlling section.

- Confirm the request or event is within the scope of Security Incident Response & Business Continuity Manual.
- Verify the authoritative worker, system, vendor, expense, incident or model record before taking action.
- Identify conditions that change the rule, including employment category, band, data classification, risk level, location, client assignment or service criticality.
- Obtain independent approval and specialist concurrence where the policy requires it.
- Record the decision, evidence, exception conditions and any expiry or follow-up date in the designated system.
- Escalate unresolved conflicts to the Policy Owner rather than creating a local workaround.

Appendices - continued

SEC-IR-004-AF Privacy Incident Coordination Checklist

Use this checklist as an execution aid. It does not create an exception or replace an approval required by the controlling section.

- Confirm the request or event is within the scope of Security Incident Response & Business Continuity Manual.
- Verify the authoritative worker, system, vendor, expense, incident or model record before taking action.
- Identify conditions that change the rule, including employment category, band, data classification, risk level, location, client assignment or service criticality.
- Obtain independent approval and specialist concurrence where the policy requires it.
- Record the decision, evidence, exception conditions and any expiry or follow-up date in the designated system.
- Escalate unresolved conflicts to the Policy Owner rather than creating a local workaround.

SEC-IR-004-AG Business Continuity Activation Checklist

Use this checklist as an execution aid. It does not create an exception or replace an approval required by the controlling section.

- Confirm the request or event is within the scope of Security Incident Response & Business Continuity Manual.
- Verify the authoritative worker, system, vendor, expense, incident or model record before taking action.
- Identify conditions that change the rule, including employment category, band, data classification, risk level, location, client assignment or service criticality.
- Obtain independent approval and specialist concurrence where the policy requires it.
- Record the decision, evidence, exception conditions and any expiry or follow-up date in the designated system.
- Escalate unresolved conflicts to the Policy Owner rather than creating a local workaround.

Appendices - continued

SEC-IR-004-AH Post-Incident Review Checklist

Use this checklist as an execution aid. It does not create an exception or replace an approval required by the controlling section.

- Confirm the request or event is within the scope of Security Incident Response & Business Continuity Manual.
- Verify the authoritative worker, system, vendor, expense, incident or model record before taking action.
- Identify conditions that change the rule, including employment category, band, data classification, risk level, location, client assignment or service criticality.
- Obtain independent approval and specialist concurrence where the policy requires it.
- Record the decision, evidence, exception conditions and any expiry or follow-up date in the designated system.
- Escalate unresolved conflicts to the Policy Owner rather than creating a local workaround.

SEC-IR-004-F01 Incident Decision Log

Field	Entry / controlled record
Requester / worker name	
Employee or worker ID	
Department / project	
Manager / sponsor	
Date / effective period	
Business purpose	
Requested action or decision	
Supporting evidence	
Approvals / concurrence	
Exception or risk notes	
Closure / outcome	
Record location	

Appendices - continued

SEC-IR-004-F02 Post-Incident Action Register

Field	Entry / controlled record
Requester / worker name	
Employee or worker ID	
Department / project	
Manager / sponsor	
Date / effective period	
Business purpose	
Requested action or decision	
Supporting evidence	
Approvals / concurrence	
Exception or risk notes	
Closure / outcome	
Record location	